INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — PaketPro 3000 Sürümü · Paketleme Makinesi

Tüm laboratuvarlar deck'in işlenmiş örnek makinesi PaketPro 3000'e uyarlanmıştır: sıcak çene + kesme bıçağı · ışık perdesi · 16 varlık + 5 dış bağlantı · internete açık uzak bakım modülü.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

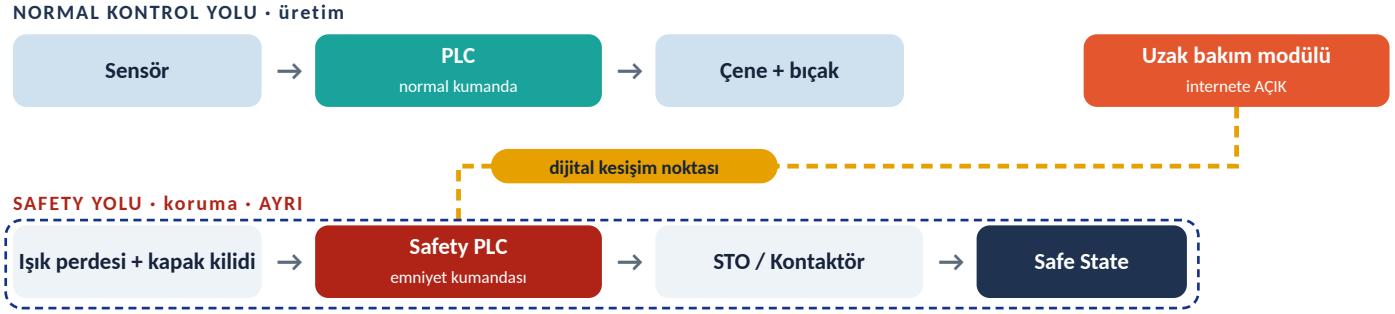
Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih 12.10.2026

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?

   Sıcak yapıştırma çenesi (yanık/ezilme) ve film kesme bıçağı (kesilme); operatörün eli/parmağı çene-bıçak bölgesine girince yaralanır.

2. Safety function (emniyet fonksiyonu) hangisidir?

   Işık perdesi + kapak kilidi → Safety PLC → STO: el bölgeye girerse veya kapak açılırsa çene ve bıçak hareketi durur.

3. Safety-related control system nerede? Şemada işaretleyin.

   Kırmızı safety yolunda: ışık perdesi + kapak kilidi + Safety PLC + STO / kontaktör (şemada kesikli çerçeveyle işaretlendi).

4. Normal PLC ile Safety PLC farkı nedir?

   Normal PLC üretimi (çene, bıçak, ritim) sürer; Safety PLC ayrı çalışır, çift kanallı/öz-tanılamalıdır, arızada STO ile güvenli duruma gider.

5. PLr / SIL neden var? Bu fonksiyon için neden önemli?

   El/parmak yaralanması ağır olduğundan risk yüksektir; PLr/SIL, bu fonksiyonun tehlikeli arıza olasılığını riske uygun düşük tutmak için gerekir.

6. Safe state (güvenli durum) nedir?

   Çene ve bıçağın enerjisi kesilmiş (STO), hareket yok; ışık perdesi/kapak kilidi arızasında veya enerji kaybında makine buna döner.

7. Safety function hangi dijital bağımlılıklara sahip?

   Safety PLC programı/parametreleri (ışık perdesi, kapak kilidi), firmware, servis hesabı, Wi-Fi/USB ile yükleme ve internete açık uzak bakım modülü bağlantısı.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?

   İnternete açık uzak bakım modülü: admin/admin ile giren saldırgan Safety PLC / ışık perdesi parametresini değiştirir veya bypass eder; safety yolu ağdan ayrılmamışsa çene ve bıçak durmaz.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · PAKETPRO 3000 · Paketleme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Üretim bölgesi: Üretim PLC, HMI, motor sürücüleri · Safety bölgesi: Emniyet PLC'si · Bakım/Uzak erişim bölgesi (DMZ): uzak bakım modülü, servis hesabı, Wi-Fi AP · Dış bölge: bulut telemetri · USB'ler: kontrollü giriş noktası.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Dış/bakım bölgesine düşer; üretim bölgesinde KALAMAZ: internete doğrudan açık kalırsa saldırgan üretim PLC'sine ve safety'ye ulaşır. DMZ'de jump server + MFA arkasında, varsayılan kapalı olmalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

İnternet↔bakım modülü (DMZ), DMZ↔Üretim, Üretim↔Safety, Üretim↔bulut telemetri, Wi-Fi/USB↔Üretim. Kontrol: güvenlik duvarı, izinli port/protokol/yön, MFA, kayıt; HMI port 80 kapatılır, USB kısıtlanır.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server — tek kontrollü giriş, doğrudan erişim yok
Tünel?	Açık / VPN	VPN — modül internete açık olmaz, şifreli kanal
Kimlik?	Parola / MFA	MFA — admin/admin tipi parola tek başına yetmez
Hesap?	Paylaşılan / Kişisel	Kişisel — admin/admin ve paylaşılan hesap kalkar
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı — olay sonrası kanıt ve denetim
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı — yalnızca onaylı bakım penceresinde açık

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · PAKETPRO 3000 · Paketleme Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Saldırgan → internete açık uzak bakım modülü + admin/admin → ışık perdesi/Safety PLC parametresi bypass edilir → çene/bıçak çalışırken el içeride → parmak ezilir/kesilir	3	3	3	27	Kritik
Kilitsiz USB → bakımda zararlı yazılım → PLC programı değişir → kapak açıkken bıçak hareketi → teknisyen kesilir	1	3	1	3	Düşük · S=3 → öne alındı
Bulut telemetri hesabı ele geçirilir → üretim verisi/reçete çalınır → üretim kaybı (insana zarar yok)	2	1	3	6	Orta

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1 — skoru 27 (Kritik): internete açık, admin/admin; sonucu doğrudan el/parmak yaralanması.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 2 (1×3×1 = 3, Düşük): S=3 olduğu için kayıtta "S=3" bayrağıyla üst sıraya alıp ayrıca işaretler, Yüksek/Kritik gibi izlerim.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO 3000 · Paketleme Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

Uzak bakım modülü internete doğrudan açık; admin/admin paylaşılan hesap, VPN/MFA yok, kayıt yok, sürekli açık; aynı düz ağda PLC, HMI ve Safety PLC var.

HEDEF (beş ilkeyle yeniden tasarlayın)

İnternet → VPN + MFA → jump server (DMZ) → kişisel hesap + tam oturum kaydı; modül varsayılan kapalı, onaylı pencerede açılır; Safety PLC ayrı bölgede, uzak yoldan erişilemez.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Etkilenmemeli: ışık perdesi / Safety PLC zinciri ayrı bölge/ağda, uzak bakım yolundan erişilemez ve normal kontrole bağımlı değildir. Yine de konfigürasyon değişirse risk doğar; bu yüzden ayrıca korunmalı.

2. Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

   Gereksinim: Işık perdesi zinciri, uzak bakım modülü ve normal PLC ele geçirilse de çene/bıçağı durdurabilmeli; safety konfigürasyonu uzaktan değiştirilememeli, yalnızca yerinde, yetkili, kayıtlı ve fiziksel anahtarla.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   SBOM ile üç şart: PaketPro firmware'inde Component X var mı, sürüm 2.4 etkileniyor mu, ağdan/internetten ulaşılabilir mi; üçü de evetse etkilenirim.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam: önce etkiyi ve erişilebilirliği değerlendirir, uzak bakım modülünü kapatır, yamayı bakım penceresine alırım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: ayrı test PLC'sinde / dijital ikizde denerim, sonra geri dönüş planıyla planlı bakım penceresinde uygularım.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet etkileyebilir: firmware ışık perdesi/STO zincirinin zamanlamasını değiştirirse; satıcı notu + etki analiziyle anlar, gerekirse yeniden doğrularım.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak bakım modülünü varsayılan kapalı tutmak, ağ segmentasyonu, MFA'lı jump server, admin/admin hesabını kaldırmak, USB/Wi-Fi'ı kısıtlamak, izleme/alarm ve yama gelene kadar sıkı log takibi.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · PAKETPRO 3000 · Paketleme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih 12.10.2026

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Hat/bakım sorumlusunu, BT/OT güvenliği ve satıcıyı ararım. İlk üç eylem: (1) emniyet — gerekirse makineyi güvenli durdur; (2) servis hesabını kapat, uzak bakım modülünü izole et; (3) saati ve olayı kaydet, kanıtı koru (reset yok).

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Işık perdesi/kapak kilidi ve STO'yu test eder, parametreleri bilinen değerle karşılaştırırım; PLC konfigürasyonunu ve erişim loglarını yedekleyip korurum; servis hesabını kapatıp parolaları değiştiririm.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Ne oldu (03:00 yetkisiz giriş), ne zaman fark edildi, etkilenen sistem (PLC/ışık perdesi), şüpheli hesap/zafiyet, ilk etki ve acil önlemler.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden ve etki: BT/OT güvenlik; önlem/yama: bakım; bildirim metni ve resmî iletişim: yönetim/yasal.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Erişim/oturum ve modül logları, PLC konfigürasyon yedekleri (önce/sonra), hesap işlemleri, ağ trafiği, alarm kayıtları, zaman damgaları.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · PAKETPRO 3000 · Paketleme Makinesi

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad | Grup | Tarih 12.10.2026

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

*Senaryo: PaketPro'ya YZ'li görsel paket kontrolü **eklenmesi planlanıyor** — proje aşaması değerlendirmesi yapıyorsunuz.*

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   Çıkışı doğrudan kabul etmem: ikinci bağımsız kontrol (ikinci sensör/ölçüm) ve örneklemeli insan onayı olur; şüpheli paket reddedilir.

   Hat hızını/ret mekanizmasını YZ değil, YZ dışındaki mimari sınırlar.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Girdi doğrulama ile (görüntü kalitesi/bütünlük, kamera sağlık kontrolü, aralık ve referans karşılaştırma) fark edilir. Şüpheli girdide YZ kararı kullanılmaz: dur/RED, insana bildir, fallback.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Eşik risk analizi ve test verisiyle belirlenir (örn. ≥ %95). Altında: paket RED + insana sor; çok düşükse hat hızı düşer/dur (fallback güvenli mod). Otomatik OK verilmez.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	İkinci kontrol + insan onayı (human override) + monitoring; hatalı OK'ta lot ayrılır, hat fail-safe durur.
Girdi manipüle edildi	Girdi doğrulama + monitoring ile fark edilir; şüpheli girdide fail-safe: hat yavaşlar/durur, paket RED, insan bilgilendirilir.
Confidence düştü	Confidence threshold: eşik altı → dur / insana sor / fallback (manuel kontrol); otomatik OK verilmez.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.